Response to Editor's and Reviewers' Comments
CYSE-D-26-01344

Evidence-Guided Crash Adjudication for LLM-assisted Fuzzing of Third-party Open-source Libraries in Connected Vehicles

Qingguan Gao, Ying Zhang, Letian Sha, and Huiran Yang

November 6, 2026

November 6, 2026

Dear Editor,

Please find enclosed the revision of our paper "Evidence-Guided Crash Adjudication for LLM-assisted Fuzzing of Third-party Open-source Libraries in Connected Vehicles" with manuscript ID CYSE-D-26-01344.

We would like to thank you for handling the review process of our paper. We are also indebted to the reviewers for their helpful comments. A detailed point-by-point response to the comments is given below.

Yours sincerely,

Qingguan Gao, Ying Zhang, Letian Sha, and Huiran Yang

Note: To help the legibility of the remainder of this response letter, all the editor's and reviewers' comments and questions are typeset in *italic font*. Our responses are written in plain font. Rephrased sentences and added content in the revised manuscript are typeset in yellow color. Quoted manuscript excerpts are also shown in yellow. Section, table, and figure references below refer to the revised manuscript.

Cybersecurity
Manuscript ID: CYSE-D-26-01344
Authors' Response to the Editor

Comment 1: *Please include a point-by-point response within the "Response to Reviewers" box in the submission system and highlight (with "tracked changes"/coloured/underlines/ highlighted text) all changes made when revising the manuscript. Please ensure you describe additional experiments that were carried out and include a detailed rebuttal of any criticisms or requested revisions that you disagree with. Please also ensure that your revised manuscript conforms to the journal style, which can be found in the Submission Guidelines on the journal homepage.*

Response: Thank you for the opportunity to revise our manuscript. We provide a point-by-point response to all nine comments from Reviewer 1 and all six comments from Reviewer 2 below. The revised manuscript incorporates the corresponding text, tables, figures, and additional experimental results. Revised text and table content are highlighted in yellow.

Cybersecurity
Manuscript ID: CYSE-D-26-01344
Authors' Response to Reviewer 1

Comment 1: *The paper correctly identifies the core issue that LLM-generated drivers are untrusted, but does not clearly delineate the specific scope of "untrusted". For example, drivers may be maliciously crafted, unintentionally erroneous, or misused due to insufficient API understanding—should attribution strategies differ across these three cases? The authors are advised to distinguish "malicious drivers" from "incompetent drivers" in the threat model and discuss the applicability of rule-guided attribution to these two categories.*

Response: Thank you for this valuable comment. We clarify the scope of "untrusted" here and explain how it relates to the three cases identified in your comment.

In this work, "untrusted" refers to driver correctness: a generated driver may contain unintentional errors or misuse an API because it lacks sufficient API understanding. Sanitizer signals and stack-frame roles provide evidence for attributing such driver-induced failures. The method does not address deliberately malicious drivers that forge evidence or conceal their provenance.

Comment 2: *Table 8 defines three ground-truth categories—"confirmed target," "confirmed non-target," and "potential target"—but does not specify the number of annotators, inter-annotator agreement (e.g., Cohen's Kappa), or whether annotators were aware of CrashSage's outputs. Given that "confirmed target" requires correspondence with public evidence such as CVEs/advisories/patches, and "potential target" is excluded from binary metrics, the authors are advised to supplement labeling protocol details and discuss whether excluding 145 potential targets may lead to optimistic estimation of method performance.*

Response: Thank you for this helpful comment on the labeling protocol and the treatment of the 145 potential-target reports. We have added a concise protocol description and included all 145 reports in the final evaluation.

Two reviewers with C/C++ memory-safety analysis experience independently examined blinded evidence without seeing CrashSage outputs. The evidence included sanitizer traces, generated drivers, target source, and local reproductions. Their paired annotations covered 31 representative groups, with 70.97% raw agreement and Cohen's kappa of 0.413. A third adjudicator reviewed the nine disagreements and the unpaired group. The audit

assigned 26 reports to target and 119 to non-target, and all 26 target reports were checked individually rather than inheriting a target label from their representative.

The final evaluation covers all 1,217 reports, containing 215 target and 1,002 non-target reports, and all V0–V4 metrics use this complete population. The 145 reports are therefore accounted for directly rather than excluded from the binary metrics.

We also report sensitivity to the 57 non-unanimous reports: V4 F1 is 0.8379 under the final labels and 0.7744 if all 57 are instead assigned to target. This analysis explicitly quantifies the effect of their treatment. The manuscript contains the protocol summary, final accounting, and sensitivity result, while detailed audit records are retained separately.

> Section 5.1
> "For the audit of the 145 previously pending reports, two reviewers with C/C++ memory-safety analysis experience independently examined evidence blinded to CrashSage outputs. The evidence included sanitizer traces, driver and target source, and local reproductions. On the 31 representative groups with paired annotations, raw agreement was 70.97% and Cohen's kappa was 0.413. A third adjudicator reviewed the disagreements and the unpaired group. All 26 reports assigned to target were subsequently checked individually; representative grouping did not replace report-level ground-truth decisions."

Comment 3: *Section 4.3 performs representative selection via exact and stack signatures, and Section 5.3 states that "each representative diagnosis and ground-truth label are propagated to its duplicate reports before computing TP, FP, and FN." However, the transitivity of signature matching (i.e., whether A matches B and B matches C implies A matches C) and the risk of error propagation (a misjudged representative causing the entire group to be misjudged) are not discussed. The authors are advised to supplement: (1) the equivalence class construction algorithm for signature matching; (2) case analysis or quantitative evaluation of group-level misjudgment caused by representative misjudgment.*

Response: Thank you for this careful reading. We have clarified the signature-matching procedure and added a quantitative assessment of representative-level prediction propagation.

CrashSage does not construct equivalence classes and does not apply a transitive closure. Exact and stack signatures are deterministic matching keys. For each report, the procedure compares its keys with those of the representatives selected so far and assigns the report to the first matching representative. If no key matches, the report becomes a

new representative. Consequently, if report A matches representative B and report C also matches B, A and C are not transitively equivalent. They are two independent reports that happen to share a signature with the same representative. Each report is mapped to at most one representative, and the mapping is stored explicitly.

We have also made the evaluation procedure explicit. Only the representative prediction is propagated through the saved mapping. Every report retains its own ground-truth label, and TP, FP, TN, and FN are computed against that label.

To quantify the propagation effect, we flip each representative prediction individually and recompute the report-level metrics. The maximum absolute F1 change is 0.0174. In the most influential case, F1 changes from 0.8379 to 0.8205 and less than 1% of report-level decisions change. This assessment makes the effect of an individual representative decision explicit on the evaluated dataset.

To clarify it, we have improved the paper as follows.

Section 5.4
"On the final 1,217-report dataset, rule-guided attribution retains 534 reports, and representative selection reduces this set to 96 representatives, a reduction of 82.02% relative to the retained workload. Only the prediction of each representative is propagated through the saved mapping. Every report retains its own ground-truth label, and TP, FP, TN, and FN are computed against that label. To evaluate group-level error propagation, we flip each representative prediction individually and recompute the report-level metrics. The maximum absolute F1 change is 0.0174; the worst-case flip reduces F1 from 0.8379 to 0.8205 and affects less than 1% of report-level decisions."

Comment 4: *Table 12 reports the runtime of rule-guided attribution and representative selection (<10 ms/report and <5 ms/report, respectively), but does not report the runtime of crash-context reconstruction and LLM analysis. Section 5.3 mentions that "runtime context reconstruction and LLM analysis are the main sources of latency," but specific data are lacking. The authors are advised to supplement: (1) detailed time breakdown of crash-context reconstruction (including seed recovery, replay, and GDB collection); (2) total end-to-end latency on the 57 representative samples; (3) discussion of scalability to larger-scale libraries (e.g., those with more APIs).*

Response: Thank you for this helpful suggestion. We have revised Table 14 and the accompanying runtime discussion to address the three points. Because the implementation

and evaluation were rechecked and expanded during revision, the historical values in this comment are superseded by the recomputed results below.

First, regarding the detailed breakdown of crash-context reconstruction, we now separately report seed recovery and binary resolution, static context extraction, direct replay, and Docker/GDB context collection. Their mean times are 0.18 ms, 1.18 ms, 2.44 s, and 18.96 s per representative, respectively. Seed recovery locates the archived crashing input, and binary resolution identifies the corresponding executable. Mean context reconstruction time is 21.72 s, with Docker/GDB collection being the dominant substep. We also report evidence packaging and prompt construction at 0.34 s and LLM analysis at 6.63 s per representative. The revised table presents the mean time for each stage, and the accompanying text explains the replay/debugger attempt limits and the inclusion of failed and timed-out attempts.

Second, regarding end-to-end latency on the representative samples, the expanded evaluation dataset contains 96 representatives, compared with 57 in the original manuscript. We have therefore updated the timing results to cover all 96 representatives. Their mean end-to-end latency is 28.69 s per representative, including context reconstruction, evidence packaging and prompt construction, and LLM analysis. This result is reported in both the revised table and the accompanying text.

Third, regarding scalability to larger libraries beyond the evaluated targets, we have expanded the discussion using cross-project measurements. The evaluated target API sets range from 12 to 60. cJSON, with 60 target APIs, reduces 78 reports to four LLM submissions, while libpcap, with 30 target APIs, reduces 115 reports to four submissions. Their mean LLM latencies are 6.17 s and 6.23 s per representative, respectively. For comparison, faad2 covers 12 target APIs and reduces 151 reports to nine submissions, with a mean LLM latency of 7.72 s. Across all 14 libraries, project-level mean LLM latency ranges from 5.52 s to 7.72 s. The higher-API examples therefore show that broader tested API coverage can still produce a compact representative workload.

These observations provide an empirical basis for discussing extension to untested libraries with larger API sets. CrashSage constructs evidence around selected crash sites and relevant execution paths, so increasing the API set does not require submitting the entire library to the model. Reports assigned to the same representative group share its diagnosis, avoiding repeated reconstruction and LLM analysis. When additional API interactions produce new representative groups, further reconstruction and model calls are required. The reconstruction cost also depends on the replay and debugger collection needed for each representative. The revised discussion therefore connects the observed cross-project results with the expected workload on larger libraries, while distinguishing representative-level inference latency from reconstruction cost.

Section 5.4

"The mean end-to-end latency across the 96 representative samples is 28.69 s, covering context reconstruction, evidence packaging and prompt construction, and LLM analysis. Context and prompt times come from the timing measurements, while LLM latency comes from the archived responses for the same representatives.

The evaluated target API sets range from 12 to 60. cJSON (60 APIs) and libpcap (30 APIs) both reduce their respective sets of 78 and 115 reports to four LLM submissions, with mean LLM latencies of 6.17 s and 6.23 s per representative. In comparison, faad2 (12 APIs) reduces 151 reports to nine submissions, with a mean LLM latency of 7.72 s. Across all 14 libraries, project-level mean LLM latency ranges from 5.52 s to 7.72 s. These results support the potential scalability of representative-based, crash-local analysis to untested libraries with larger API sets. The analysis workload for such libraries would depend on representative count and per-representative replay/debugger cost."

Comment 5: *Table 7 defines V0 as the "CKGFuzzer baseline," but CKGFuzzer is itself a fuzz driver generation system whose crash adjudication capability is not its design goal. Is it fair to use it as a crash adjudication baseline? The authors are advised to supplement: (1) comparative experiments with dedicated crash deduplication/localization methods (e.g., Igor, ReBucket, CrashLocator); (2) comparison with a baseline that directly uses LLM to classify raw reports; (3) discussion of why CKGFuzzer was chosen over other LLM-assisted fuzzing systems (e.g., PromptFuzz, Fuzz4All) as the baseline.*

Response: Thank you for this valuable comment. The comment raises three points: whether CKGFuzzer is a fair crash-adjudication baseline, which dedicated methods and which raw-report baseline the comparison should include, and why CKGFuzzer was chosen over other LLM-assisted fuzzing systems. We address them in turn.

On the fairness of the baseline, CKGFuzzer enters the comparison as the complete crash-cause analysis pipeline rather than as a driver generator alone. Its crash-analysis stage is active in V0, so the comparison does not credit CrashSage with adjudication that the baseline already performs. All variants share the same driver generation and fuzzing workflow, and the V0–V4 comparison therefore measures the four added stages on top of that pipeline.

On dedicated methods, we apply ReBucket to the same 534 reports retained after rule-guided attribution, as the reference for the selection stage. ReBucket selects 103 cluster representatives and CrashSage selects 96, corresponding to reductions of 80.71%

and 82.02%, and the pairwise Jaccard agreement is 0.9824. We also examined Igor and CrashLocator. Both operate on a crash corpus format and a debug-information setup that differ from the ASan+UBSan reports used here, so applying them would change the corpus and the attribution target, and the comparison would no longer isolate adjudication quality. ReBucket operates on stack traces and applies to the retained reports without changing the corpus, so it serves as the reproducible reference.

On the raw-report LLM baseline, we pass each of the 1,217 reports directly to the same model with a minimal direct instruction, without filtering, representative selection, reconstructed context, or the differential prompt. It performs the same binary decision as CrashSage and obtains Precision 0.2010, Recall 0.5488, and F1 0.2943, against 0.7654, 0.9256, and 0.8379 for CrashSage.

On the choice of CKGFuzzer, it provides the driver generation, fuzzing, and crash-analysis workflow on which this study builds. PromptFuzz and Fuzz4All target input or driver generation and do not expose the crash-analysis interface used here. Replacing CKGFuzzer with either system would change the crash corpus, the build and sanitizer settings, and the labeling conditions, so the comparison would conflate upstream fuzzing effectiveness with downstream adjudication quality.

To clarify it, we have improved the paper as follows.

> Section 5.2
> "To assess the effect of analyzing unprocessed crash reports directly, we compare a raw-only LLM baseline with the complete CrashSage V4 on the same 1,217 reports and ground-truth labels. The raw-only baseline passes each original sanitizer report to `qwen3-coder-flash` at temperature 0 with a minimal attribution instruction, without filtering, representative selection, reconstructed context, or the differential prompt."

Comment 6: *Section 5.1 uses Qwen3-Coder-Plus as the primary model, and Section 5.5 compares Qwen3.7-Max and Qwen-Flash. However, it is not explained why the Qwen series was chosen over other commercial models such as GPT-4 or Claude. Additionally, cloud API version updates may render results irreproducible. The authors are advised to supplement: (1) rationale for model selection (cost, availability, code understanding capability, etc.); (2) model version numbers and access dates; (3) whether open-source local models (e.g., CodeLlama, DeepSeek-Coder) were considered to enhance reproducibility.*

Response: Thank you for this valuable comment. We have added the model-selection

rationale and the reproducibility information, and explain our consideration of locally deployed models below.

The default backend of CrashSage is `qwen3-coder-flash`. The selection follows four practical criteria: general and code-analysis capability on C/C++ crash evidence, a context window large enough to hold the evidence package, service stability and response latency, and API cost. We now state these criteria alongside the evaluated model configuration.

For reproducibility, we report the API model identifiers, endpoint information, access dates, and decoding parameters. All configurations use `temperature=0`. We retain the raw model responses in the experiment archive, allowing the reported behavior to be inspected alongside the provider-managed model identifiers and access dates.

On locally deployed open-source models, thank you for this suggestion. We considered this option. Given the hardware and context-budget constraints of this study, we used hosted backends to keep the evidence budget consistent across evaluated models. We appreciate the stronger control over model revisions offered by a fixed local deployment. For the reported experiments, the API model identifiers, access dates, decoding settings, and archived raw responses document the evaluated configurations.

To clarify it, we have improved the paper as follows.

> Section 5.6
> "The primary CrashSage-V4 model is `qwen3-coder-flash`, accessed on 1 November 2026 through the OpenAI-compatible endpoint `https://llm-1aqn2a1i6uz9t6gu.cn-beijing.maas.aliyuncs.com/compatible-mode/v1`. This model was selected on four engineering metrics: general and code-analysis capability, long-context capacity, service stability and response latency, and API cost."

Comment 7: *Table 15 shows that differential prompting improves recall from 0.829 to 0.952 but slightly decreases precision. Table 16 shows that the prompt significantly improves cJSON and json-c but not tinyxml2. This indicates that the effect of prompt design is project-dependent. The authors are advised to supplement: (1) stability experiments of differential prompting across different LLM models; (2) whether there is a risk of prompt overfitting (i.e., tuning prompts for specific libraries); (3) ablation experiments on prompt templates to identify key prompt components.*

Response: Thank you for this valuable comment. We have added cross-backend and repeated-run stability tests, explained the safeguards against library-specific tuning, and conducted a nested prompt ablation. We address the three points below.

First, stability across models. We evaluate the complete V4 pipeline with six backends, including three non-Qwen backends, `deepseek-flash`, `gpt-5.6-sol`, and `glm-5.3-flash`, while keeping the representatives, reconstructed evidence, prompt, mapping, and ground truth fixed. F1 ranges from 0.8240 to 0.8379 and recall from 0.9163 to 0.9256. We also repeat each prompt configuration six times at temperature 0. Mean F1 is 0.7788, 0.8095, 0.8260, and 0.8295 for P0–P3, respectively; standard deviations range from 0.0051 to 0.0100, and decisions vary for 9–23 of the 1,217 reports across runs.

Second, safeguards against overfitting and project-dependent effects. The prompt template was frozen before evaluation and shared across all libraries. It contains no library-specific instructions, CVE identifiers, or ground-truth labels; project evidence is supplied separately. Only cJSON, expat, and jansson change between V3 and V4; the other eleven projects retain the same results.

The large cJSON improvement follows from its representative mapping. Of 78 reports, six are target and 72 non-target. Filtering retains 14 reports, which map to four representatives; all six targets belong to one group comprising the representative and five duplicates. V3 classifies this representative as non-target, V4 as target, using the same evidence and mapping. Propagation therefore changes TP from 0 to 6 and FN from 6 to 0, while FP remains 0 and TN remains 72, raising F1 from 0.0000 to 1.0000. In the selected P1 run, this representative already changes after the two-hypothesis comparison is added. The large gain thus reflects one improved decision covering all six positives, rather than six independent model decisions.

Other projects have different group distributions and starting points. In expat, one changed representative recovers seven of 13 targets; the other six retain their prior predictions, giving precision 1.0000, recall 0.5385, and F1 0.7000. In jansson, V3 recall is already 1.0000. V4 corrects 14 false positives covered by two representatives, reducing FP from 21 to 7 and improving precision from 0.3824 to 0.6500. For unchanged projects, dlt-daemon and faad2 already have F1 1.0000, whereas tinyxml2 and json-c retain the same representative predictions and F1 values of 0.4878 and 0.7879. V4 structures reasoning over unchanged evidence, so gains depend on which representative decisions change and how many reports they cover.

Third, component ablation. We compare four nested variants using the same representatives and evidence. P0 is the V3 Clean direct prompt; P1 adds the two-hypothesis comparison; P2 adds precondition checking and `evidence_rationale`; P3 adds boundary

rules and corresponds to V4. F1 increases from 0.7815 to 0.8139, 0.8257, and 0.8379, respectively.

The decision counts explain these contributions. P1 increases TP from 186 to 199 and reduces FN from 29 to 16, while FP remains 75. Recall therefore rises from 0.8651 to 0.9256 without increasing the false-positive count. P2 and P3 then reduce FP to 68 and 61, while TP stays at 199. The later checks remain useful after recall plateaus: they refine positive attributions through caller-precondition and supporting-evidence checks. In this nested comparison, hypothesis comparison provides the largest initial F1 gain, while precondition auditing and boundary rules further improve precision. The components thus combine recovery of missed targets with more selective attribution, preserving the recall gain while reducing false alarms.

We have incorporated these experiments and explanations into the revised manuscript.

Revised manuscript: Section 5.6, Tables 20, 21, 22, and 23.

Comment 8: *The title and introduction emphasize connected vehicle scenarios, but the experimental section is conducted only on general third-party open-source libraries, without involving connected-vehicle-specific communication protocols (e.g., CAN, MQTT, DDS), real-time constraints, or security authentication mechanisms. The authors are advised to supplement: (1) specific mapping between the selected libraries and connected vehicle functions, along with security impact analysis; (2) whether connected-vehicle-specific crash patterns (e.g., timing-related crashes, resource contention crashes) were considered; (3) discussion of the method's applicability in the context of automotive-grade certification (e.g., ISO 26262).*

Response: Thank you for this helpful comment. We have clarified the connected-vehicle application setting and address the three points as follows.

First, the subject table maps the evaluated libraries to representative connected-vehicle functions. These include diagnostic logging through dlt-daemon, inter-module transport through isotp-c, and networking, configuration and telemetry processing, compression, media processing, and archive handling through the remaining libraries. The accompanying text explains that defects in these components may affect diagnostic records, communication, configuration handling, update processing, and media services.

Second, the added transport and logging targets exercise stateful API sequences and resource lifecycles at the component level. The revised text distinguishes this coverage from vehicle-level timing and concurrent resource-contention validation, which require a system-level execution setting.

Third, CrashSage prepares attribution evidence for further engineering inspection. We distinguish this supporting role from ISO 26262 compliance assessment and automotive certification. A brief clarification in the experimental setup defines this scope, while the abstract and introduction retain connected vehicles as the application scenario.

> Section 5.1
> "Stateful API sequences in isotp-c and dlt-daemon extend the component-level evaluation to transport and logging lifecycles. Vehicle-level timing failures and concurrent resource contention require separate system-level validation. CrashSage provides crash-attribution evidence for further engineering analysis; ISO 26262 compliance assessment and certification remain distinct from the component-level evaluation reported here."

Comment 9: *Representative selection compresses 258 reports into 57 representative samples, reducing LLM submissions by 77.91%. However, different crash reports may correspond to different vulnerability instances under the same CVE, or different manifestations of the same vulnerability under different inputs. The authors are advised to supplement: (1) analysis of the correspondence between signature matching and CVE uniqueness; (2) whether there is a risk of misclassifying different vulnerabilities as duplicates; (3) discussion of vulnerability diversity lost after deduplication.*

Response: Thank you for this comment. We have added structural and CVE audits to explain the relationship between report counts, representative groups, and vulnerability identities. We address the three questions in turn.

On the correspondence between signature matching and CVE uniqueness, the audit uses three units, and each unit contains the next. A report belongs to one representative group, a group belongs to one crash site, and a crash site is associated with at most one CVE. The two levels below the CVE reduce the report count for two different reasons. Many reports collapse into one group when they share a signature, which is the common case because different drivers often reproduce the same crash in the same way. One crash site then spreads over several groups when its reports reach the same function through different call paths, because the signature carries the call stack and a different path produces a different signature. The 215 confirmed-target reports form 42 groups over 16 crash sites. Of these 215 reports, 80 carry an explicit public CVE identifier, and these 80 reports form 19 groups over 7 CVEs. One CVE in tinyxml2 illustrates the relation. Its 13 reports occupy six groups, and all six groups reach the same crash function, so the groups differ in call path rather than in crash site. Signature matching therefore does not reproduce CVE boundaries. It reproduces crash-site boundaries at a finer scale.

On the possibility of merging different vulnerabilities, the audit inspects every group and lists the CVE identifiers and structural crash-site fingerprints of its members. All 19 groups containing CVE-linked reports are homogeneous in CVE identifier, and all 42 confirmed-target groups are homogeneous in the audited structural fingerprint. Pairwise precision is 1.0000 against both references. These observations establish consistency with the audited CVE and structural classes; the structural fingerprint serves as an auditable crash-site proxy.

On vulnerability diversity after deduplication, representative selection reduces the 534 retained reports to 96 representatives, a reduction of 82.02%. All 16 crash sites and all 7 CVEs remain represented after selection. The 135 confirmed targets outside the CVE subset are drawn from publicly documented driver-and-PoC cases without an assigned CVE identifier, from the two automotive components added in this revision, and from the completed audit of the previously pending reports. The representative set therefore covers disclosed vulnerabilities, documented cases without an identifier, and newly audited targets.

To clarify it, we have improved the paper as follows.

Section 5.4

"We audit whether representative selection merges distinct confirmed targets in two complementary views. The structural audit covers all 215 confirmed-target reports and groups them by project, sanitizer bug type, first target-project frame, and crash function. The CVE audit covers the 80 reports with explicit public CVE identifiers. As summarized below, neither audit merges distinct confirmed targets, and all target and CVE categories remain represented after selection."

Cybersecurity
Manuscript ID: CYSE-D-26-01344
Authors' Response to Reviewer 2

Comment 1: *Clarify the connection between the connected vehicles and the technical contribution. Section 5.1 explicitly focuses on third-party libraries rather than a complete vehicle software stack, and Table 6 lists their representative deployment roles. However, the technical challenges, method design, and evaluation mainly reflect general crash analysis of open-source libraries. It remains unclear what automotive-specific requirements motivate or affect the design of CrashSage. If the connected vehicles is central to the paper, representative software stacks or realistic integration configurations would strengthen the evaluation. Otherwise, the paper could position CrashSage as a general crash-adjudication approach and present automotive software as one application scenario. The corresponding scope and applicability limitations should also be clarified in Section 6.*

Response: Thank you for this helpful comment. We have clarified the distinction between the application setting and the technical contribution. Connected-vehicle software is the application scenario considered in this study; the technical problem addressed by CrashSage is the uncertain correctness of LLM-generated fuzz drivers. The title is retained to identify this application scenario, while the abstract and introduction make this distinction explicit.

The method uses sanitizer evidence, stack-frame roles, representative matching, and reconstructed execution context. These designs address driver/component attribution and do not depend on a vehicle-specific protocol or an on-vehicle execution environment. The evaluated libraries provide the concrete application workload, and the subject table records their representative roles in connected-vehicle software.

Section 6 now specifies component-level crash adjudication as the evaluation scope and distinguishes it from full-stack, ECU-integration, and on-vehicle validation. We appreciate the suggestion and have aligned the abstract and introduction with this application setting and scope.

Section 1
"In this study, connected-vehicle software provides the application setting rather than a vehicle-specific prerequisite of the method, and the evaluation focuses on its third-party-library components."

Section 6

"The evaluation covers third-party-library components relevant to connected-vehicle software. Its scope is component-level crash adjudication; full vehicle stacks, ECU integration, and on-vehicle deployment remain separate validation settings. The reported results and their applicability are interpreted within this component-level scope."

Comment 2: *Expand the diversity of experimental targets. The current evaluation covers 12 libraries, mainly involving structured-data parsing, media decoding, networking, and compression/archive processing. Although these targets are practically relevant, broader API usage patterns would provide stronger evidence of generalization. In particular, the authors could consider targets involving state management, resource lifecycles, invocation-order constraints, or other complex API contracts. The paper should also clarify the target-selection criteria and deployment limitations.*

Response: Thank you for this valuable comment. The comment raises four points: the target-selection criteria, the API usage patterns that the current targets exercise, the addition of targets with state and lifecycle contracts, and the deployment limitations. We address them in turn.

On the selection criteria, a library enters the evaluation if it is publicly available, is relevant to the connected-vehicle supply chain, builds under ASan+UBSan within the CKGFuzzer workflow, and produces crashes that can be reproduced. The final set contains 14 libraries, and all 12 libraries of the previous version are retained in it.

On the API usage patterns, we now quantify the interaction that the generated drivers exercise rather than the functional category of each library. The 14 projects contain 186 generated drivers, between 7 and 22 per project. The median number of distinct target APIs per driver ranges from 2 to 8 across projects, and 179 of the 186 drivers (96.2%) call at least two distinct target APIs. 168 drivers (90.3%) also include at least one initialization or cleanup call, so the dominant pattern is an ordered sequence that opens with setup and closes with release.

On the state and lifecycle targets, we added `isotp-c` and `dlt-daemon` to cover transport and logging components. The recorded drivers exercise ordered calls and resource lifecycles. For example, the `dlt-daemon` driver calls `dlt_filter_init`, `dlt_filter_load`, `dlt_filter_add`, `dlt_filter_find`, `dlt_filter_delete`, and `dlt_filter_free` in order, and the `isotp-c` driver calls `isotp_receive`, `isotp_continue_receive`, `allocate`, and `free_allocated`. These examples document component-level interaction patterns; vehicle-level timing and concurrency remain separate validation settings.

On the deployment scope, Section 6 identifies third-party-library components as the evaluation layer and distinguishes this setting from full vehicle-stack, ECU-integration, and on-vehicle validation.

To clarify it, we have improved the paper as follows.

> Section 5.1
> "We select 14 publicly available libraries that can be built under ASan+UBSan within the CKGFuzzer workflow and represent software functions relevant to connected-vehicle supply chains. The set covers gateway networking, diagnostic logging, inter-module transport, configuration and telemetry processing, packet capture, compression, media handling, and archive processing. We characterize exercised API diversity by recording multi-API calls and ordered lifecycle calls involving initialization, creation, opening, allocation, receiving, use, and cleanup."

Comment 3: *Clarify the effect of rule-based filtering. Table 9 shows that all 146 ground-truth positive reports are retained after filtering, yet Tables 10 and 11 show noticeable Recall differences between V0 and V1, particularly for expat, json-c, and libpcap. The paper explains that the false negatives in V1 come from subsequent LLM decisions rather than filtering, but it remains unclear why retained positive reports receive different predictions between the two configurations. Please clarify whether normalization, triage information, or other model inputs differ between V0 and V1. If the effective inputs and model settings are otherwise unchanged, repeated runs would help determine whether model variability contributes to these differences.*

Response: Thank you for this careful reading. The comment asks three things: whether the model inputs differ between V0 and V1, why a retained positive report can receive a different prediction, and whether model variability contributes to the difference. We address them in turn.

On the model inputs, the two configurations receive different evidence. V0 receives the raw crash report. V1 receives the normalized crash report together with the triage label and the matched-rule evidence. Both configurations use the same model, the same temperature, and the same output schema, so the input is the only difference between them. In the revised evaluation the confirmed target reports number 215, and all of them remain in the 534 retained reports.

On why a retained positive report can change prediction, the full-population comparison combines a change in the report population with a change in the supplied evidence,

so we add a controlled comparison on the same 534 retained reports. The V0 predictions are fixed and rescored on this subset, with no additional V0 calls. V0 obtains Precision 0.6537, Recall 0.7023, and F1 0.6771; V1 obtains 0.5894, 0.7209, and 0.6485. When the V0 predictions are restricted to the retained reports, precision rises from 0.2817 to 0.6537, because the 683 filtered reports are all non-targets and 305 of the V0 false positives fall in that set. The remaining difference on the common population is attributable to the input. On this population 172 reports change decision, and 52 of them are target reports. The change is bidirectional: 28 target reports move from negative to positive and 24 move from positive to negative, a net gain of four. The three libraries named in the comment show how the change is distributed. expat has five target reports that move to negative and two that move to positive. libpcap has two that move to negative and four that move to positive. json-c has no changed report on this population. A retained target report therefore receives a different prediction because the normalized report and the rule evidence change the model decision.

On model variability, we quantify the run-to-run variation of a fixed configuration, as the comment suggests. The main configuration was repeated six times at temperature 0. The mean F1 is 0.8295 with a standard deviation of 0.0085, the 95% run-bootstrap interval is [0.8220, 0.8355], and 23 of the 1,217 reports change decision across the six runs. The repeated runs therefore reproduce the same decision on 98.1% of the reports, and the 172 reports that change between V0 and V1 follow the change in the supplied evidence.

To clarify it, we have improved the paper as follows.

Section 5.3

"V0 and V1 use different report populations and different inputs. V0 uses the raw crash report. V1 uses the normalized crash report, triage labels, and matched-rule evidence. The full-population comparison captures the combined effect of report filtering and evidence preparation. We also compare both configurations on the same 534 retained reports. As shown in Table 12, V1 identifies more confirmed target reports than V0 on this common population. These results show that rule-guided attribution reduces the analysis workload while retaining all confirmed target reports. They also show that V1 prepares structured evidence for the later context-reconstruction and final-prompt stages. The effects of these stages are evaluated separately in the V2–V3 and V3–V4 comparisons."

Comment 4: *Strengthen the evaluation of model stability and generalization. The experiments use temperature 0, but deterministic decoding does not necessarily establish*

run-to-run stability when using a cloud-hosted LLM. Repeating the main experiments and reporting the variation in key metrics would make the conclusions more robust. In addition, Table 17 evaluates three Qwen models under the same evidence package and prompt, but all belong to the same model family. If feasible, including a representative model from another family would provide stronger evidence that the observed benefits are not specific to Qwen models.

Response: Thank you for this valuable comment. The comment asks for two additions: repeated runs that quantify run-to-run variation, and a backend from another model family. We address them in turn.

On run-to-run stability, we repeat the main experiment six times at temperature 0 and report the variation in the key metric. For the full CrashSage configuration, the mean F1 is 0.8295 with a standard deviation of 0.0085, and the 95% run-bootstrap interval is [0.8220, 0.8355]. Across the four repeated configurations, the standard deviation lies between 0.0051 and 0.0100, and the number of reports whose decision changes across the six runs is between 9 and 23 out of 1,217. The conclusions therefore hold under repetition of the same configuration.

On other model families, we repeat the complete V4 experiment with five additional backends, three of which belong to other model families: `deepseek-flash`, `gpt-5.6-sol`, and `glm-5.3-flash`. The representatives, reconstructed contexts, prompt, representative mapping, and ground-truth labels are held fixed, and only the final LLM is replaced. F1 ranges from 0.8240 to 0.8379 and Recall from 0.9163 to 0.9256 across the six backends. The three non-Qwen backends reach 0.8354, 0.8354, and 0.8312, which places them inside this range.

To clarify it, we have improved the paper as follows.

Section 5.6

"Run-to-run stability. The four prompt configurations defined in the prompt-component ablation were frozen before evaluation and shared across projects. No project names, expected CVE identifiers, or ground-truth labels were inserted into the templates. We repeated each configuration six times at temperature 0 and report decision variability at both the run and report levels. The main table uses the formal V3/V4 endpoints for P0/P3 and the median-F1 runs recorded in the experiment manifest for P1/P2; both selected intermediate runs are run1. The P2 and P3 intervals overlap, so their difference is interpreted as an observed effect rather than a statistically significant improvement."

Comment 5: *Clarify the CKGFuzzer baseline and comparison with prior work. Section 5.1 states that crash reports are collected following the fuzz-driver generation and fuzzing workflow of CKGFuzzer, while Table 7 labels V0 as the "CKGFuzzer baseline" and describes it as having no filtering, selection, or context reconstruction and using a clean direct prompt. It is therefore unclear whether V0 represents the complete crash-analysis procedure of CKGFuzzer or only uses its upstream workflow to generate crash reports. The authors should clearly specify which CKGFuzzer components are retained or modified. If V0 does not include its original crash-analysis procedure, a separate comparison with the complete method would provide a fairer baseline. Comparisons with other representative methods directly related to crash attribution or false-positive identification would also help establish the advantages of CrashSage beyond its internal ablations.*

Response: Thank you for this valuable comment. The comment raises four points: what V0 contains, which CKGFuzzer components are retained or added, whether a separate comparison with the complete method is needed, and how CrashSage compares with other representative methods. We address them in turn.

On what V0 contains, V0 is the complete CKGFuzzer crash-cause analysis pipeline, not a reuse of the upstream workflow with an empty analysis stage. The upstream driver generation and fuzzing workflow is shared by all variants, and the crash-analysis stage of CKGFuzzer is active in V0.

On the retained and added components, the four components evaluated in V1–V4, namely rule-guided filtering, representative selection, context reconstruction, and the differential prompt, are CrashSage additions and are disabled in V0. The configuration table now labels V0 as *complete CKGFuzzer*, and the text states which components are retained and which are added. Because the upstream workflow is held fixed across V0–V4, the comparison measures the added stages on top of the complete CKGFuzzer pipeline.

On the comparison with the complete method, V0 retains the complete CKGFuzzer crash-analysis procedure. The V0–V4 endpoints therefore provide this comparison directly, and we have made that relationship explicit in the configuration table and accompanying text.

On other representative methods, we add two external references. A raw-report LLM baseline passes each of the 1,217 reports directly to the same model with a minimal direct instruction, without filtering, representative selection, reconstructed context, or the differential prompt. It performs the same binary decision as CrashSage, so it is the direct reference for false-positive identification. It obtains Precision 0.2010, Recall 0.5488, and F1 0.2943, against 0.7654, 0.9256, and 0.8379 for CrashSage. We also apply ReBucket to the same 534 reports retained after rule-guided attribution, as the external reference for

the selection stage. ReBucket selects 103 cluster representatives and CrashSage selects 96, corresponding to reductions of 80.71% and 82.02%. At the pairwise level, ReBucket preserves 1,450 of the 1,476 report pairs that CrashSage groups together, and the pairwise Jaccard agreement is 0.9824.

We also examined Igor and CrashLocator as candidate references. Both operate on a crash corpus format and a debug-information setup that differ from the ASan+UBSan reports used here, so applying them would change the corpus and the attribution target, and the comparison would no longer isolate adjudication quality. ReBucket operates on stack traces and applies to the retained reports without changing the corpus, so it serves as the reproducible external reference for the selection stage.

To clarify it, we have improved the paper as follows.

Section 5.1
"V0 is the complete CKGFuzzer crash-cause analysis pipeline. The rule-guided filtering, representative selection, crash-context reconstruction, and differential prompt evaluated in V1–V4 are CrashSage enhancements and are disabled in V0. The V0–V4 comparison therefore measures the incremental effect of these added stages while holding the complete CKGFuzzer workflow fixed."

Comment 6: *Improve figure readability. Some figures, particularly the pipeline diagrams, contain text that is difficult to read at normal viewing scale. Increasing the font size and simplifying the layout would improve readability. Vector graphics should be used where appropriate.*

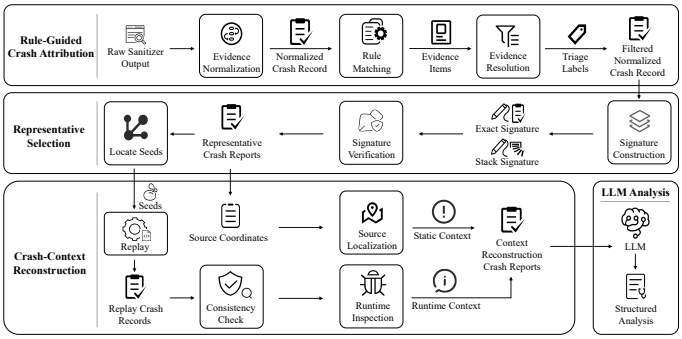
Response: Thank you for this valuable comment. The comment raises three points: the label size in the pipeline diagram, the layout of that diagram, and the use of vector graphics. We address them in turn.

On the label size, we enlarged the labels of the pipeline figure (Fig. 2) and set its canvas to the width at which it is inserted. The figure is inserted at 0.75 linewidth, and the previous canvas was 1,086 pt wide, so its 16 pt labels were reduced to about 3.8 pt at print size. The new canvas is set to the insertion width, and the stage titles now appear at about 7.9 pt and the body labels at about 6.7 pt at print size, without further reduction.

On the layout, the four stages and their order are unchanged, and the arrows that connect them are kept. The revision enlarges the labels and adjusts the spacing inside each stage so that the larger labels fit without overlap. The pipeline therefore shows the same four stages in the same sequence as before.

On vector graphics, Fig. 2 now contains no raster element and every label is vector text, so the figure stays sharp at any zoom level and at print resolution. Fig. 1 carries vector text labels on raster icons, and its labels remain legible at the width used in the paper, so the icon set is kept. The result figures are regenerated as vector PDFs. All figures are checked at the width at which they are inserted before submission.

To clarify it, we have improved the paper as follows.



Revised Figure 2.